ĐẠI HỌC
BÁCH KHOA HÀ NỘI
HANOI UNIVERSITY
OF SCIENCE AND TECHNOLOGY

KIỂM CHỨNG NGƯỠNG CVSS 8,0 CỦA CSA VÀ ĐỀ XUẤT CÔNG THỨC ƯU TIÊN VÁ LỖ HỔNG

Kết hợp CVSS, EPSS, CISA KEV và Chỉ thị BOD 26-04

Trường Công nghệ Thông tin và Truyền thông, Đại học Bách khoa Hà Nội

Học phần Chính sách và Quản trị an ninh mạng

Giảng viên: TS. Nguyễn Đức Toàn, TS. Lê Xuân Thành

Trần Minh Vương : 20252023M

Vũ Thành Huy : 20252033M

Nguyễn Hoà Khiêm : 20252031M

ONE LOVE. ONE FUTURE.

Ngưỡng CVSS 8,0 vá thừa và bỏ sót; công thức S chọn đúng chỗ hơn nhiều lần

98,69%

lỗ hổng phải vá trong 48 giờ chưa từng bị khai thác (65.845 / 66.722)

16 đến 34 lần

nhóm S từ 70 hiệu quả hơn chọn ngẫu nhiên; quy tắc CSA chỉ 1,7 đến 2,3 lần

2,7 đến 8,9 lần

số lỗ hổng sắp bị khai thác S bắt được so với xếp theo CVSS khi chỉ vá 1% đến 5%

1	CH1	Quy tắc CVSS 8,0 vá thừa và bỏ sót bao nhiêu? Vá thừa ở mọi cách đọc; bỏ sót từ 21% đến 44%
2	CH2	Công thức S có tốt hơn khi chỉ dùng thông tin có tại ngày quyết định? Có, rõ nhất khi nguồn lực vá có hạn
3	Đề xuất	Thang điểm S kèm hạn vá thay cho ngưỡng CVSS cố định, bám theo BOD 26-04
4	Giới hạn	Ngang EPSS dùng riêng; chưa cảnh báo được lỗ hổng mới công bố; AC, PE, EA chưa kiểm chứng

CSA đề xuất vá trong 48 giờ mọi lỗ hổng CVSS trên 8,0 phơi ra Internet

BẰNG CHỨNG BÀI BÁO CSA DẪN

87% và 7% — GPT-4 khai thác 87% trong 15 lỗ hổng một ngày khi có mô tả CVE, chỉ 7% khi không có

86% — Hệ thống tại DARPA AIxCC 2025 tìm ra 86% lỗ hổng tổng hợp và 18 lỗ hổng thật

37 / 40 — Incalmo tự động chiếm tài sản quan trọng ở 37 trên 40 môi trường mô phỏng

QUY TẮC CẦN KIỂM CHỨNG

CVSS trên 8,0 và hệ thống phơi ra Internet: vá trong 48 giờ

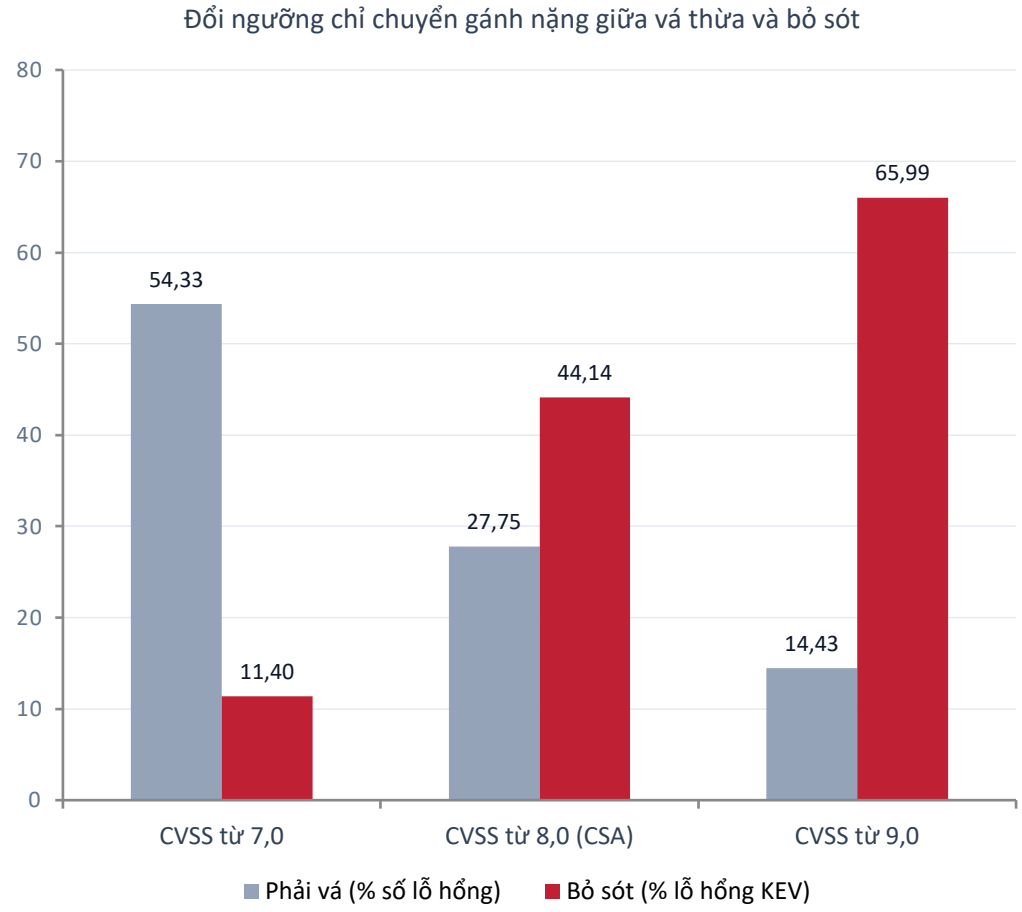
CSA không giải thích hay kiểm chứng ngưỡng 8,0, dù chính bài báo khuyên phải coi trọng khả năng bị khai thác

HAI CÂU HỎI CỦA BÀI

CH1 Trên dữ liệu thật, quy tắc ngưỡng CVSS 8,0 vá thừa và bỏ sót bao nhiêu?

CH2 Công thức kết hợp nhiều nguồn có sắp thứ tự ưu tiên tốt hơn quy tắc đó, khi chỉ dùng thông tin có tại thời điểm quyết định?

98,69% lỗ hổng phải vá chưa từng bị khai thác, 44,14% lỗ hổng bị khai thác bị bỏ qua



240.409 lỗ hổng có CVSS 3.x trong NVD (1999 đến 2025), 1.570 lỗ hổng trong KEV

98,69%

nhóm phải vá trong 48 giờ chưa từng bị khai thác (65.845 / 66.722): vá 76,1 lỗ hổng mới gặp 1 lỗ hổng bị khai thác

44,14%

lỗ hổng KEV có CVSS dưới 8,0 nên bị bỏ qua (693 / 1.570)

1,06% đến 1,54%

lỗ hổng bị khai thác trong nhóm phải vá, ở cả ba ngưỡng

Không ngưỡng CVSS nào giảm được cả hai lỗi.

Đọc khuyến nghị CSA sát hơn chỉ giảm bỏ sót, vá thừa vẫn giữ nguyên

Cách đọc khuyến nghị	Phải vá	Bỏ sót KEV	Bị khai thác trong nhóm vá	Vá cho 1 ca
Q0. CVSS từ 8,0	27,75%	44,14%	**1,31%**	76,1
Q1. CVSS trên 8,0 (nghĩa chặt)	27,35%	44,71%	**1,32%**	75,8
Q2. Q0, chỉ lỗ hổng khai thác qua mạng (AV:N)	35,97%	26,25%	**1,34%**	74,6
Q3. Q0 hoặc đã có PoC công khai	29,01%	33,12%	**1,51%**	66,4
Q4. Q3, chỉ lỗ hổng AV:N	37,11%	20,73%	**1,40%**	71,6

Q2 và Q4 chỉ xét 174.803 lỗ hổng có vector AV:N, xấp xỉ điều kiện phơi ra Internet; PoC lấy từ Exploit-DB

1,31% đến 1,51%

nhóm phải vá bị khai thác ở mọi cách đọc: phải vá 66 đến 76 lỗ hổng mới gặp 1 ca

HÀM Ý

Vấn đề nằm ở thước đo: CVSS không chứa thông tin lỗ hổng có đang bị khai thác hay không.

CISA đã bỏ hạn vá theo CVSS, chuyển sang bốn biến rủi ro trong BOD 26-04

BỐN CÂU HỎI CÓ HOẶC KHÔNG, CHO TỪNG LỖ HỔNG TRÊN TỪNG TÀI SẢN

Phơi ra Internet

Tài sản có truy cập được từ mạng công cộng?

Có trong KEV

Lỗ hổng đã bị khai thác thực tế?

Tự động hóa được

Kẻ tấn công tự động hóa được toàn bộ chuỗi khai thác?

Tác động kỹ thuật

Khai thác xong chiếm toàn quyền hay một phần?

HẠN VÁ THEO TỔ HỢP CÂU TRẢ LỜI (BẢNG 1 CỦA CHỈ THỊ)

3 ngày	3 ngày	14 ngày	60 ngày	Lần nâng cấp
kèm điều tra xâm nhập				hệ thống kế tiếp

Không còn yêu cầu dùng CVSS để xếp ưu tiên khi thu hồi BOD 19-02 (hướng dẫn thực hiện, 10/06/2026)

Chỉ 26% lỗ hổng KEV được khắc phục hoàn toàn năm 2025, giảm từ 38% (Verizon DBIR 2026, CISA dẫn trong blog)

Công thức S gộp năm nguồn thông tin thành một điểm ưu tiên từ 0 đến 100

$$S = AC \times CVSS \times [\, KEV \times PE + (1 - KEV) \times (\, EA \times PE + (1 - EA) \times EPSS^{0,3} \,) \,] \times 10$$

Phần trong ngoặc vuông là bộ lọc mối đe dọa T, nhận giá trị từ 0 đến 1

AC

Mức quan trọng của tài sản

0 đến 1, tổ chức tự xác định (CMDB)

CVSS

Mức nghiêm trọng kỹ thuật

0 đến 10, từ NVD

KEV

Đã bị khai thác thực tế

1 nếu có trong danh mục KEV

EA

Tự động hóa được (BOD 26-04)

1 nếu Automatable là Yes (Vulnrichment)

PE

Phơi ra Internet (BOD 26-04)

1 nếu tài sản truy cập được từ Internet

EPSS

Xác suất bị khai thác trong 30 ngày

0 đến 1, từ FIRST

Bộ lọc mối đe dọa tự rẽ năm nhánh mà không cần câu lệnh điều kiện

KEV	EA	PE	T	Ý nghĩa
1	0 hoặc 1	1	**1**	Đã bị khai thác, tiếp cận được từ Internet: mức cao nhất
1	0 hoặc 1	0	**0**	Đã bị khai thác nhưng nằm trong mạng nội bộ: hạ ưu tiên, xử lý bằng quy tắc chính sách
0	1	1	**1**	Tự động hóa được và phơi ra Internet: mức cao nhất, không chờ EPSS
0	1	0	**0**	Tự động hóa được nhưng công cụ quét từ Internet không nhìn thấy
0	0	0 hoặc 1	**$EPSS^{0,3}$**	Không tự động hóa được: điểm tăng dần theo EPSS, kể cả trong mạng nội bộ

VÌ SAO PE KHÔNG NHÂN VỚI EPSS

EPSS học từ tấn công toàn cầu, gồm cả thư lừa đảo, mối đe dọa nội bộ, VPN. Lỗ hổng trong mạng nội bộ vẫn có thể bị tấn công, nên không để về 0.

VÌ SAO SỐ MŨ 0,3

Phần lớn EPSS rất nhỏ. Số mũ nén thang mà giữ thứ tự: 0,001 thành 0,13; 0,01 thành 0,25; 0,1 thành 0,50. Thử từ 0,2 đến 1,0 cho kết quả gần như nhau.

Cùng CVSS 9,0: trên Internet được 90 điểm, trong mạng nội bộ còn 0

	CVSS	EPSS	KEV	EA	PE	Điểm S	Quy tắc CSA
A	9,8	0,001	0	0	1	**12,3**	Vá trong 48 giờ
B	7,5	0,90	0	0	1	**72,7**	Bỏ qua
C	6,5		1		1	**65,0**	Bỏ qua
D	9,0	0,10	0	1	1	**90,0**	Vá trong 48 giờ
E	9,0	0,10	0	1	0	**0,0**	Ngoài phạm vi
F	8,8		1		0	**0,0**	Ngoài phạm vi
G	7,8	0,30	0	0	0	**54,4**	Ngoài phạm vi

Số liệu giả định, AC = 1

ĐỌC VÍ DỤ

- D lên đầu vì tự động hóa được và phơi ra Internet; nếu EA = 0 chỉ còn 45,1
- B xếp thứ hai dù CSA bỏ qua: EPSS 0,90
- A chỉ 12,3 vì gần như không có tín hiệu khai thác
- C vào nhóm khẩn cấp nhờ quy tắc KEV dù điểm 65
- G nội bộ vẫn 54,4 nhờ EPSS

Kiểm thử ngược chỉ dùng thông tin có tại ngày đánh giá, so ở cùng khối lượng vá

1. Chọn ngày T

trong quá khứ, ví dụ 30/06/2025

2. Chấm điểm S

bằng EPSS lịch sử và KEV có tại ngày T

3. Theo dõi 12 tháng

lỗ hổng nào thực sự vào KEV

4. So sánh

với quy tắc CSA và xếp theo CVSS ở cùng khối lượng vá

PHẠM VI ĐÃ KIỂM CHỨNG

$$S0 = AC \times CVSS \times [\, KEV + (1 - KEV) \times EPSS^{0,3} \,] \times 10$$

Dạng rút gọn khi PE = 1 (đúng phạm vi CSA) và EA = 0; thực nghiệm đặt AC = 1. Hiệu suất = tỷ lệ bắt được chia tỷ lệ khối lượng vá, tức gấp bao nhiêu lần chọn ngẫu nhiên.

QUY MÔ KIỂM CHỨNG

240.409

lỗ hổng có CVSS 3.x trong NVD, 1.570 lỗ hổng trong KEV

11

ngày đánh giá cuối quý, 03/2023 đến 09/2025

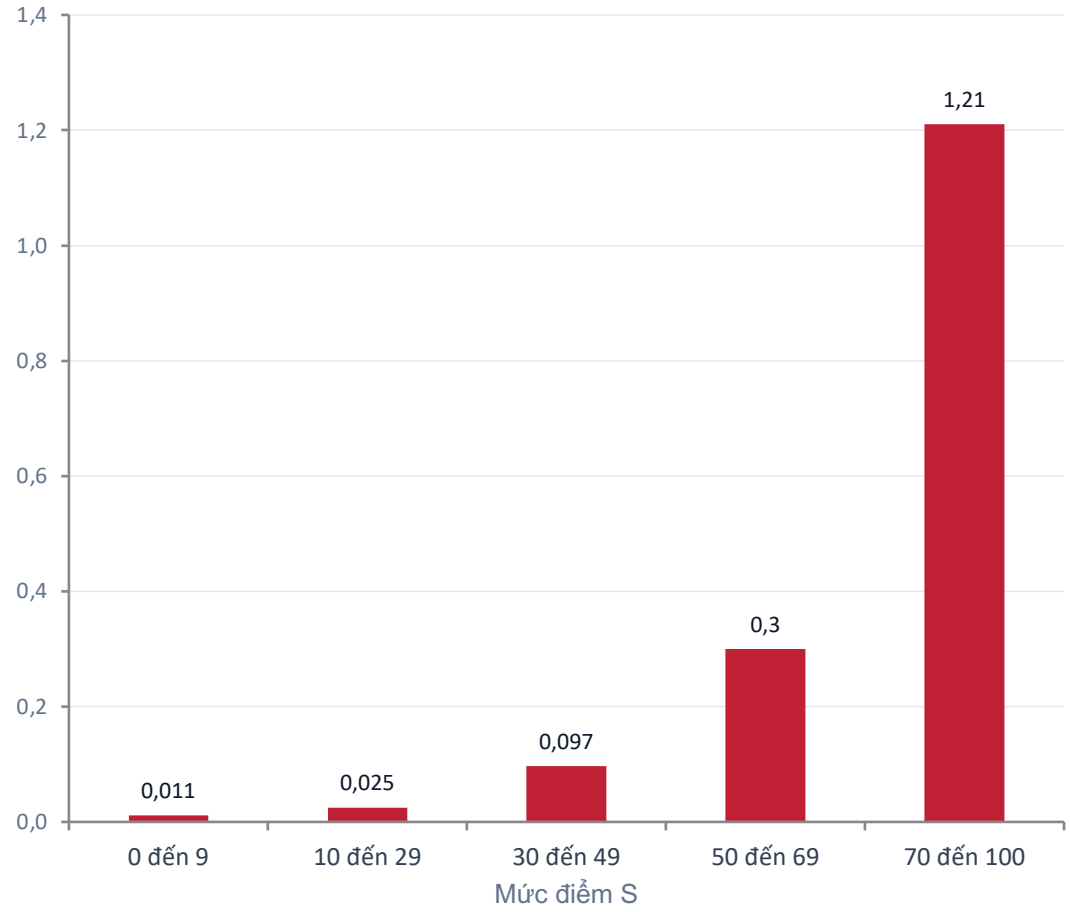
1.000

lần lấy mẫu bootstrap cho khoảng tin cậy 95%

H1

đặt trước: ở khối lượng của CSA, S bắt được nhiều hơn CVSS

Tỷ lệ bị khai thác tăng đều theo điểm S: mức từ 70 gấp 28 lần trung bình



1,34%

số lỗ hổng chưa có trong KEV đạt S từ 70 (2.803 / 209.623)

34 / 91

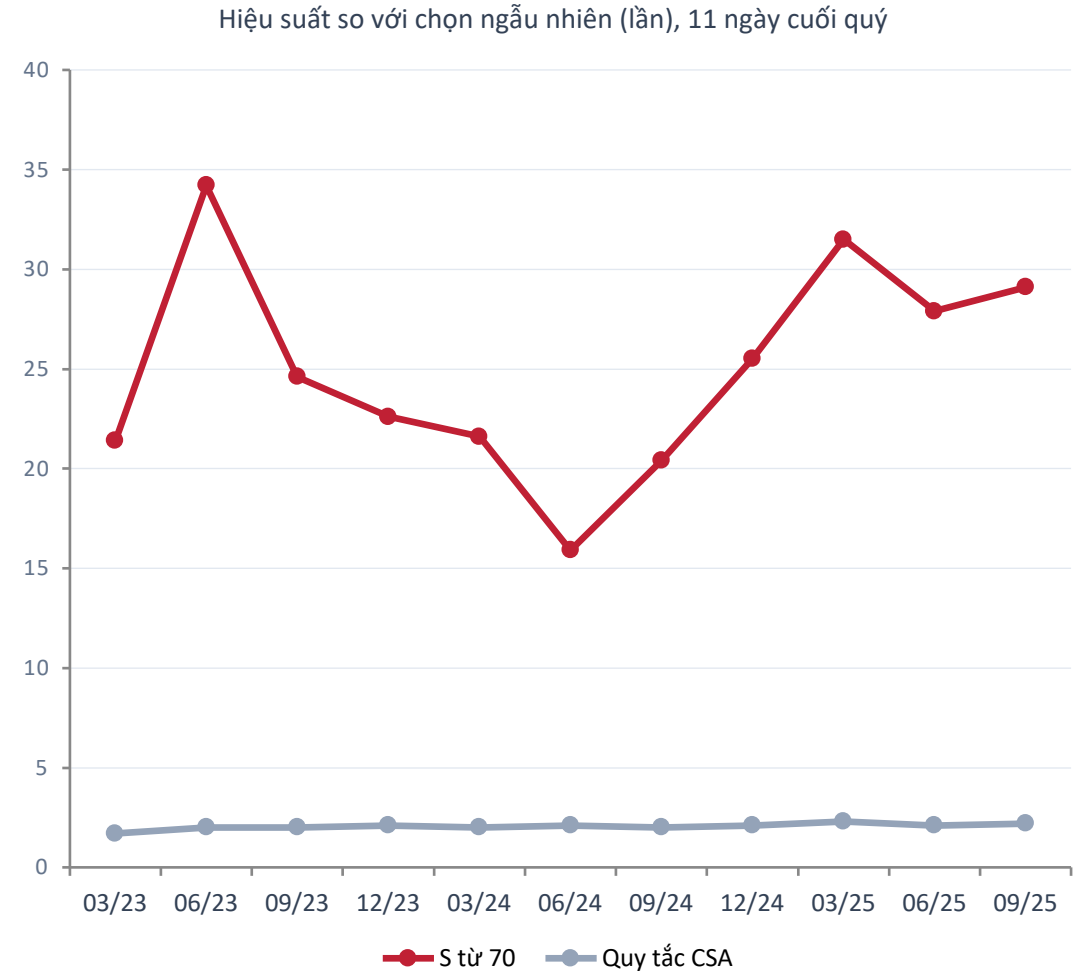
lỗ hổng sắp bị khai thác nằm trong nhóm nhỏ này (37,36%)

0,043%

tỷ lệ vào KEV trung bình của 209.623 lỗ hổng

Gấp trung bình: 0,3; 0,6; 2,2; 7; 28 lần.

S từ 70 hiệu quả gấp 16 đến 34 lần ngẫu nhiên, quy tắc CSA chỉ 1,7 đến 2,3 lần



1,34% / 27,73%

khối lượng vá của S từ 70 so với quy tắc CSA, ngày 30/06/2025

82 / 1.076

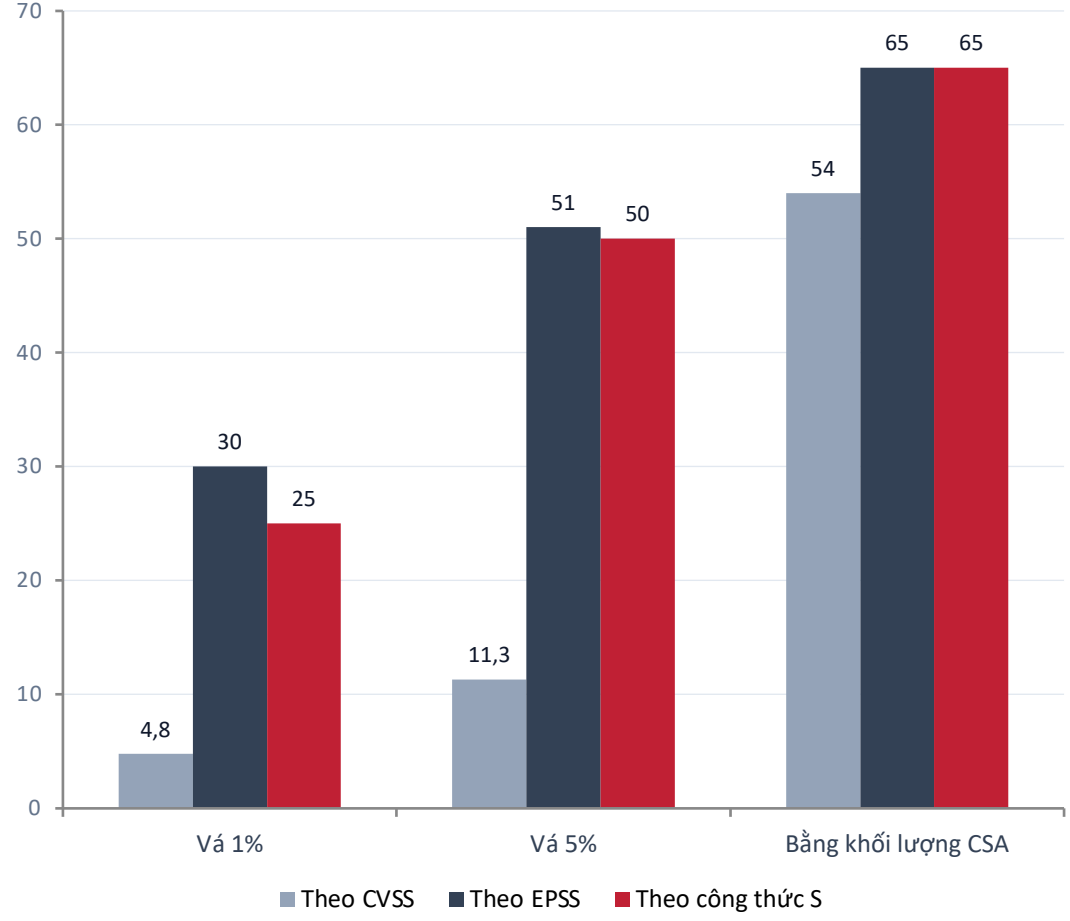
lỗ hổng phải vá cho mỗi lỗ hổng bắt được: S từ 70 so với quy tắc CSA

13 / 15

trường hợp S bằng hoặc hơn quy tắc khi vá cùng khối lượng với từng cách đọc Q0 đến Q4

Tính cả lỗ hổng KEV, nhóm vá khẩn cấp theo S chỉ 1,44% đến 1,98%, thay vì khoảng 28%.

Khi chỉ vá 1% đến 5% số lỗ hổng, S bắt được nhiều gấp 2,7 đến 8,9 lần xếp theo CVSS



ĐÃ CHỨNG MINH

Vá 1% hoặc 5%: khoảng tin cậy 95% nằm trên 0; qua 11 ngày S không kém CVSS ngày nào

H1 CHƯA ĐẠT

Ở khối lượng CSA: hơn CVSS 6,0 ca, khoảng tin cậy từ -2,0 đến +15,0 có chứa 0

SO VỚI EPSS

Gần như ngang: khả năng dự đoán chủ yếu đến từ EPSS

CSA bỏ qua 24 lỗ hổng KEV mà S đã xếp ưu tiên trước khi CISA xác nhận

CVE-2021-26086

Atlassian Jira, CVSS 5,3

S khoảng 50 liên tục từ 02/2024, 8 tháng trước khi vào KEV (12/11/2024)

CVE-2023-32315

Openfire, CVSS 7,5

S tăng 7, 34, 62 trong hai tháng sau công bố, gần 1 tháng trước khi vào KEV (24/08/2023)

CVE-2015-5477

ISC BIND, CVSS 7,5

S khoảng 73 liên tục từ 02/2022; CISA xác nhận ngày 08/10/2026, tức 55 tháng sau

24 / 156

lỗ hổng KEV có CVSS dưới 8,0, có EPSS, đạt S từ 50 vào 30 ngày trước khi vào KEV (15,38%)

14,3 tháng

trung vị thời gian S giữ liên tục lỗ hổng trong nhóm ưu tiên trước khi CISA xác nhận

ĐỌC ĐÚNG TÌNH HUỐNG

- Báo trước là trước khi CISA xác nhận, chưa chắc trước khi bị khai thác
- 12 / 24 lỗ hổng đạt 50 lần đầu đúng tháng EPSS đổi mô hình
- 119 / 156 = 76,28% vẫn dưới 30 điểm trước khi vào KEV

Danh sách 24 lỗ hổng: phần lớn được giữ trong nhóm ưu tiên trên 12 tháng

Mã CVE	CVSS	S trước 30 ngày	Giữ liên tục (tháng)	Lần đầu đạt 50
CVE-2015-5477	7,5	73,0	55	Đổi mô hình
CVE-2019-9621	7,5	73,1	49	Tháng đầu
CVE-2019-5418	7,5	73,7	49	Tháng đầu
CVE-2021-43798	7,5	73,7	45	Tháng đầu
CVE-2020-17519	7,5	74,3	36	Tháng đầu
CVE-2021-22054	7,5	72,4	35	Đổi mô hình
CVE-2018-9276	7,2	59,3	35	Đổi mô hình
CVE-2020-9715	7,8	65,6	34	Tăng dần
CVE-2020-25078	7,5	73,6	28	Đổi mô hình
CVE-2017-3506	7,4	73,3	27	Đổi mô hình
CVE-2016-9079	7,5	74,4	16	Đổi mô hình
CVE-2016-6415	7,5	74,4	15	Đổi mô hình

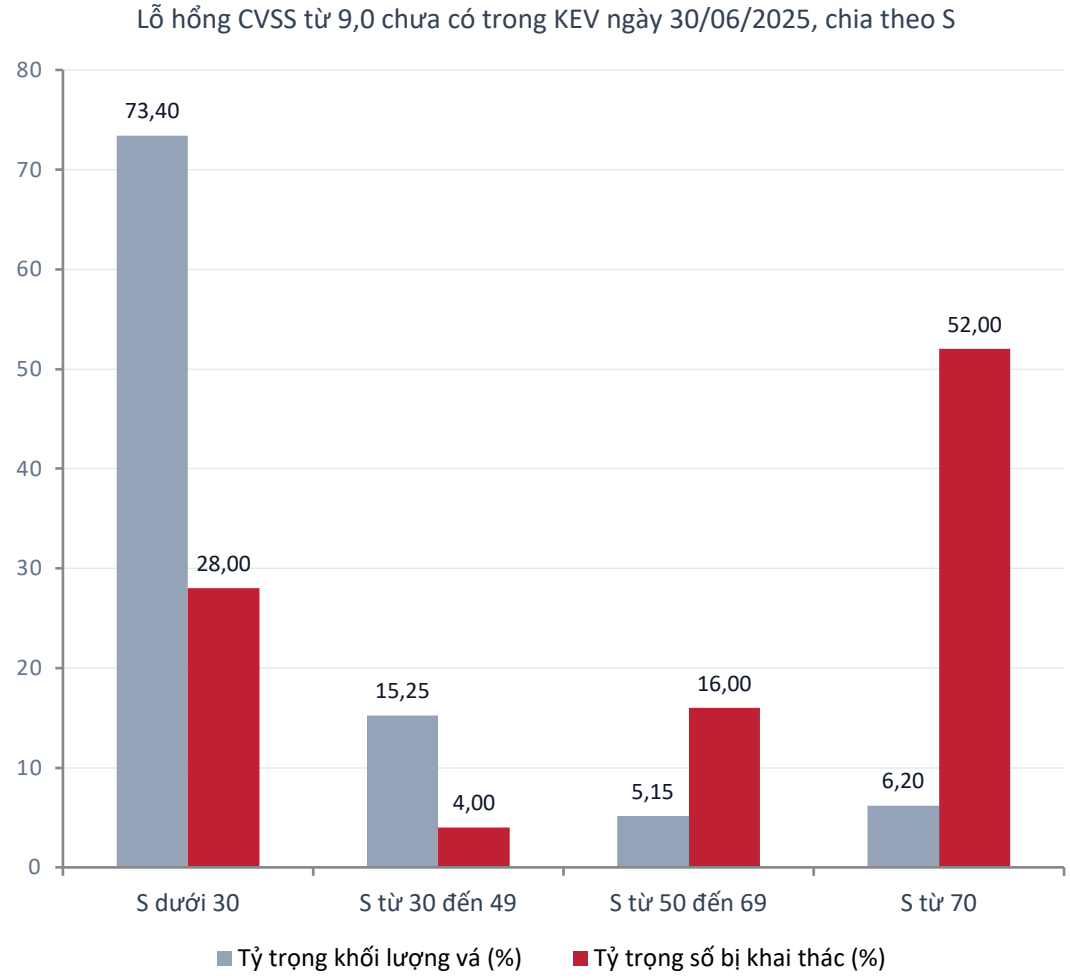
Mã CVE	CVSS	S trước 30 ngày	Giữ liên tục (tháng)	Lần đầu đạt 50
CVE-2022-43769	7,2	52,8	14	Tăng dần
CVE-2024-21182	7,5	72,1	14	Đổi mô hình
CVE-2024-27199	7,3	71,8	13	Đổi mô hình
CVE-2021-39935	7,5	51,3	9	Tăng dần
CVE-2021-41277	7,5	73,9	8	Đổi mô hình
CVE-2021-26086	5,3	50,6	8	Đổi mô hình
CVE-2021-22555	7,8	73,6	6	Tăng dần
CVE-2021-21311	7,2	69,2	6	Đổi mô hình
CVE-2023-24955	7,2	51,9	6	Tăng dần
CVE-2023-27351	7,5	58,9	4	Tăng dần
CVE-2023-32315	7,5	61,8	1	Tăng dần
CVE-2023-0386	7,8	50,3	1	Tăng dần

12 **Đổi mô hình**
lần đầu đạt 50 trùng tháng EPSS đổi mô hình

4 **Tháng đầu**
đạt 50 ngay tháng đầu có điểm

8 **Tăng dần**
điểm tăng dần theo EPSS giữa hai lần đổi mô hình

CVSS từ 9,0: nhóm S từ 70 chỉ 6,2% khối lượng nhưng chứa 52% ca bị khai thác



25 / 30.308

lỗ hổng CSA yêu cầu vá trong 48 giờ thực sự vào KEV trong 12 tháng (0,082%)

73,40%

khối lượng này được S hạ ưu tiên xuống dưới 30 điểm

22 lần

tỷ lệ bị khai thác của nhóm S từ 70 (0,692%) so với nhóm dưới 30 (0,031%)

Cái giá: nhóm bị hạ vẫn chứa 7 / 25 = 28% số ca bị khai thác.

Thay ngưỡng CVSS cố định bằng thang điểm S có hạn vá theo từng mức

Khẩn cấp	KEV hoặc tự động hóa được, trên tài sản phơi ra Internet	**3 ngày**
Nghiêm trọng	S từ 70 đến 100: gấp 28 lần trung bình	**7 ngày**
Cao	S từ 50 đến 69: gấp 7 lần	**14 ngày**
Trung bình	S từ 30 đến 49: gấp 2,2 lần	**30 ngày**
Thấp	S từ 10 đến 29: 0,6 lần	**60 ngày**
Rất thấp	S từ 0 đến 9: 0,3 lần	**Lần nâng cấp kế tiếp**

Tài sản nội bộ (S = 0) vẫn có hạn theo BOD 26-04: lỗ hổng KEV 14 ngày, hoặc 3 ngày kèm điều tra nếu tự động hóa được và chiếm toàn quyền; tự động hóa được 60 ngày

Xét điều kiện khẩn cấp trước, xét điểm sau.

CĂN CỨ SỐ LIỆU

1,34%

khối lượng vá của mức Nghiêm trọng

37,36%

lỗ hổng sắp bị khai thác nằm trong mức này

Hạn 7, 14, 30, 60 ngày theo mức điểm là đề xuất của nhóm, chưa kiểm chứng; hạn 3, 14, 60 ngày lấy theo BOD 26-04. Hiệu chỉnh ngưỡng khi EPSS đổi mô hình.

Giới hạn: S gần như ngang EPSS và chưa cảnh báo được lỗ hổng mới công bố

27,15%

lỗ hổng vào KEV từ 01/04/2023 chưa có EPSS trước khi vào KEV (227 / 836): zero-day, chỉ thành phần KEV xử lý được

4,46%

lỗ hổng công bố tối đa 30 ngày trước khi vào KEV đạt S từ 70 một ngày trước đó

45,8%

độ phủ ước tính của dữ liệu Vulnrichment (Securin), nguồn của biến tự động hóa EA

CHƯA CHỨNG MINH ĐƯỢC

- So với EPSS dùng riêng: gần như ngang
- AC và PE: cần danh mục tài sản của tổ chức
- Căn cứ KEV chậm, nghiêng về sản phẩm phổ biến ở Mỹ
- Điểm CVSS của NVD thường được chấm sau ngày công bố
- Số mũ 0,3 không tối ưu chung; 0,2 đến 1,0 gần như nhau

Với lỗ hổng mới, chính sách vẫn cần quy tắc KEV, cảnh báo nhà cung cấp và tình báo mối đe dọa.

Thay ngưỡng CVSS bằng điểm S đặt bằng chứng khai thác vào trung tâm

KẾT LUẬN

1. Ngưỡng CVSS 8,0 vá thừa 98,69% và bỏ sót 21% đến 44%; đổi ngưỡng không giải quyết được

2. Nhóm vá khẩn cấp theo S chỉ 1,4% đến 2% số lỗ hổng, hiệu suất 16 đến 34 lần so với 1,7 đến 2,3 lần của CSA

3. Khuyến nghị thang điểm S thay ngưỡng cố định, cùng hướng với BOD 26-04

HƯỚNG PHÁT TRIỂN

- Thêm tín hiệu sớm cho lỗ hổng mới công bố: PoC, cảnh báo nhà cung cấp
- Kiểm chứng biến EA bằng dữ liệu Vulnrichment
- Kiểm chứng PE và AC trên dữ liệu tài sản của một tổ chức cụ thể

HUST

hust.edu.vn fb.com/dhbkhn

THANK YOU !

Trường Công nghệ Thông tin và Truyền thông, Đại học Bách khoa Hà Nội